

SEC102

**MENACES INFORMATIQUES ET CODES
MALVEILLANTS ANALYSE ET LUTTE**



SEC102

**MENACES INFORMATIQUES ET CODES MALVEILLANTS
ANALYSE ET LUTTE**

Equipe pédagogique SEC102



Fabrice CRASNIER, enseignant FSI à UT3 en M2 SSIR/STRI/ISSD, expert de justice près la Cour d'Appel de Toulouse, dirigeant SASU CyberFabLab expertises et formations
tel : 06.24.49.39.20,
mail : fabrice.crasnier@cyberfablab.fr



Anthony DESSIATNIKOFF, vacataire M2 SSIR, dirigeant de CodiTrust tests d'intrusion et Formateur cybersécurité,
tel : 06.31.57.30.75,
mail : anthony@coditrust.com,
Site web : <https://www.coditrust.com>.



Félix Guyard, dirigeant de forensicXlab, tel : 06.82.82.16.68,
mail : felix.guyard@forensicxlab.com,
twitter : @k1nd0ne,
site web : <https://www.forensicxlab.com/>

Calendrier prévisionnel de la formation

Cours	Date	Titre du cours	Enseignant
01	mar. 07/03/2023 (sem. 10)	Présentation du cours SEC 102 avec le fil rouge : la gestion de l'incident de sécurité en entreprise, Introduction à la gestion de l'incident de sécurité en entreprise	Fabrice CRASNIER
02	mer. 15/03/2023 (sem. 11)	Le métier de pentester et ses contraintes	Anthony DESSIATNIKOFF
03	mer. 22/03/2023 (sem. 12)	Les méthodes d'intrusion sur les systèmes, méthodologie du hacker pour créer une intrusion (en VM)	Anthony DESSIATNIKOFF
04	mar. 28/03/2023 (sem. 13)	Posture de la DSI face à un incident de sécurité. Présentation de la prestation de réponse sur incident, gestion de crise (mise en place des outils de crise).	Fabrice CRASNIER
05	mer 05/04/2023 (sem 14)	De l'investigation sur le réseau (ingénieur réseaux) à la collecte des données, Exploitation et analyse des journaux réseaux.	Félix GUYARD
06	mer 12/04/2023 (sem 15) Distanciel	De l'investigation sur le système (ingénieur système) à la collecte des données. Exploitation et analyse des données syslog/sysmon	Félix GUYARD
07	lun. 17/04/2023 (sem.16)	Analyse de malwares	Anthony DESSIATNIKOFF

06 - mer. 12/04/2023 (sem. 15)

MENACES INFORMATIQUES ET CODES MALVEILLANTS ANALYSE ET LUTTE

Exploitation et analyse des journaux réseaux.

Objectifs

Connaître et comprendre les protocoles d'intérêt à la cybersécurité (Cours).

Connaître et identifier les attaques (Cours).

Connaître des outils de surveillance du réseau pour la prévention et l'investigation (Cours/TD).

Bonnes pratiques pour la collecte des journaux réseaux (Cours).

Investiguer et analyser du trafic dans un réseau compromis par un acteur malveillant (TD/TP).

- Introduction
- Les différents types de journaux réseaux
- Techniques, tactiques et procédures des attaquants
- Méthodologie de surveillance
- Les outils d'investigation et de détection
- Méthodologie d'investigation

Rappel

Évènements réseau

Application

Transport

Réseau

Liaison

Physique

802.11

SMTP

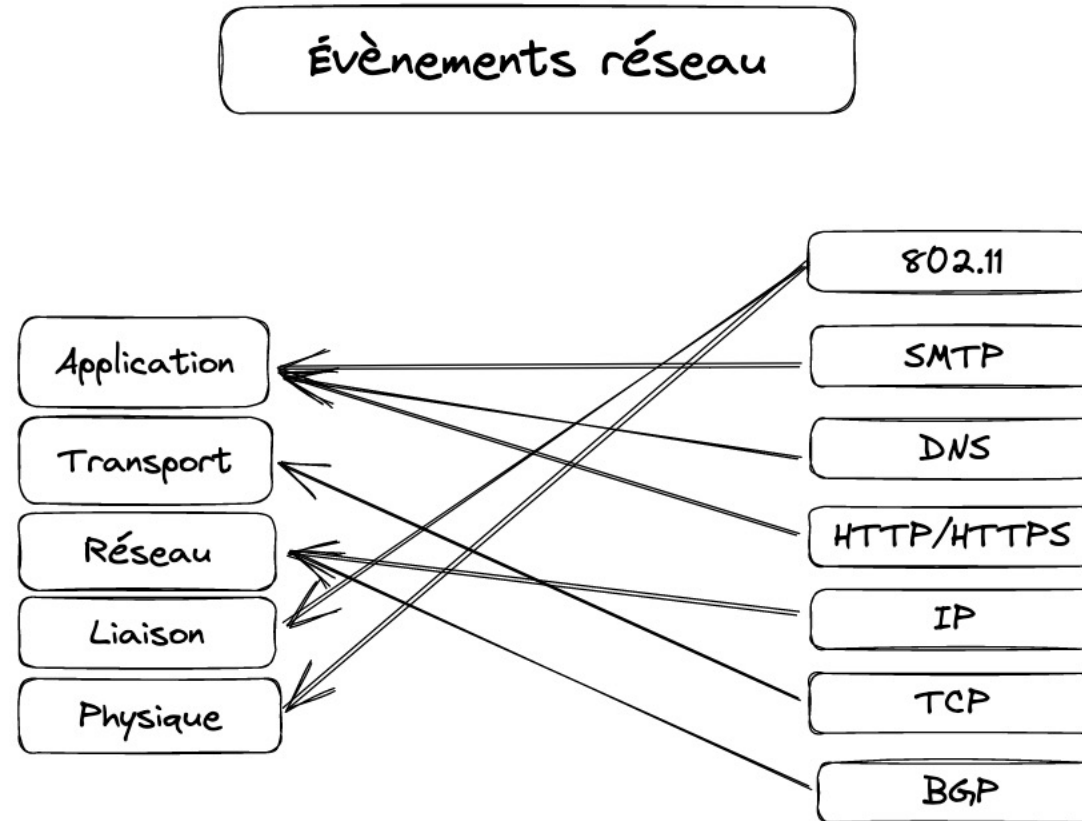
DNS

HTTP/HTTPS

IP

TCP

BGP



- Introduction
- Les différents types de journaux réseau
- Techniques, tactiques et procédures des attaquants
- Méthodologie de surveillance
- Les outils d'investigation et de détection
- Méthodologie d'investigation

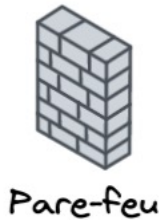
10

Capture de paquets :

- Bruts
- Verbeux
- Intéressant dans le cadre d'une analyse à cours terme pointue (analyse malware par exemple).

Fichiers de logs :

- Moins verbeux (information légère et plus pertinente)
- Sources multiples:
 - Serveurs
 - Pare-feux
 - NIDS/NIPS
 - ...



Problème : Taxonomie et format des logs très hétérogène !

- Introduction
- Les différents types de journaux réseau
- **Techniques, tactiques et procédures des attaquants**
- Méthodologie de surveillance
- Les outils d'investigation et de détection
- Méthodologie d'investigation

12

Les services exposés

Attaques par déni de service distribué (DDOS)

Scans massifs et tentatives d'exploitation de vulnérabilités (nmap, wfuzz, ...)

Hameçonnage : Campagnes de phishing, spearphishing...

L'ensemble des protocoles exposés est à considérer comme prioritaire dans la surveillance et lors d'une investigation numérique.

13

Détournement des protocoles http/https

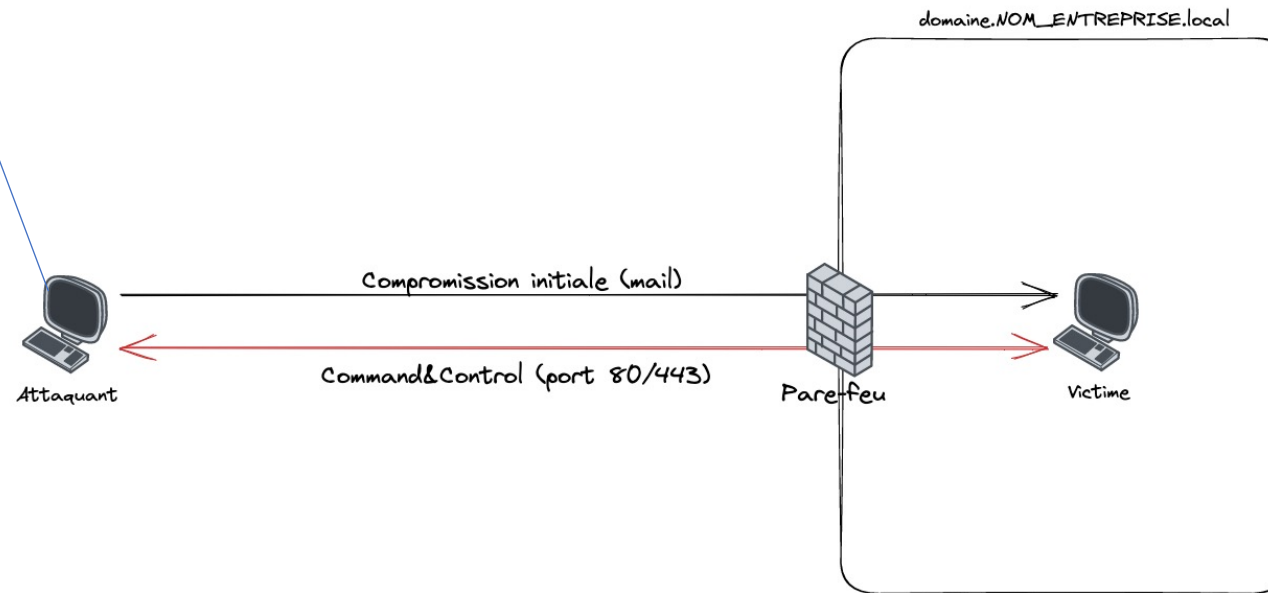
Exemple : Cobalt Strike



Rendre la compromission inaperçue.

Contourner les restrictions liées au pare-feu

Technique utilisée par la plus part des **loader**, **malware**, **WebShell** et framework de **Command&Control**



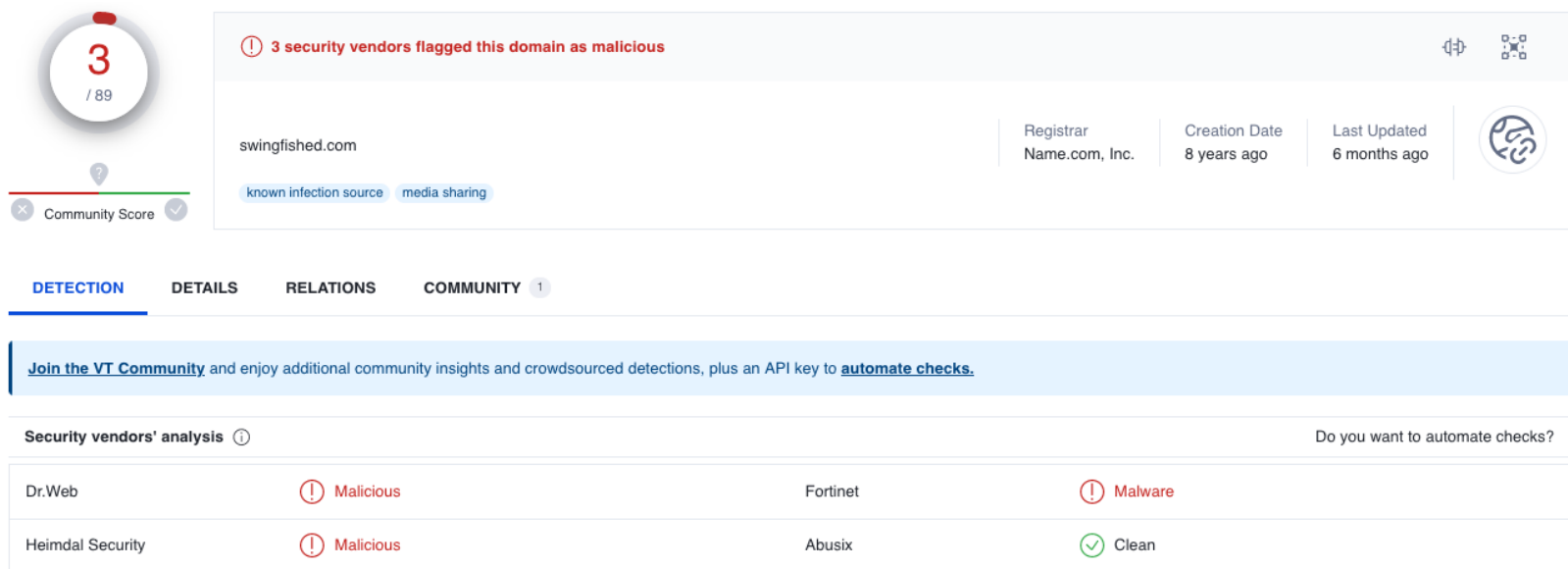
14 Détection et investigation

Analyse de paquets : Rechercher des données qui sortent de l'ordinaire (analyse statistique)

Analyse de trafic : Comparer les requêtes HTTP à un trafic « usuel »

Historique des domaines contactés => Recherche de « nouveaux » domaines

Analyse sur l'enregistrement des domaines (whois) / Réputation des domaines (VirusTotal...)



The screenshot shows the VirusTotal interface for the domain **swingfished.com**. On the left, a circular badge displays a **3** out of 89 score, with a 'Community Score' label below it. A warning banner at the top states: **3 security vendors flagged this domain as malicious**. Below this, the domain name is listed with tags for **known infection source** and **media sharing**. To the right, a table provides registration details:

Registrar	Creation Date	Last Updated
Name.com, Inc.	8 years ago	6 months ago

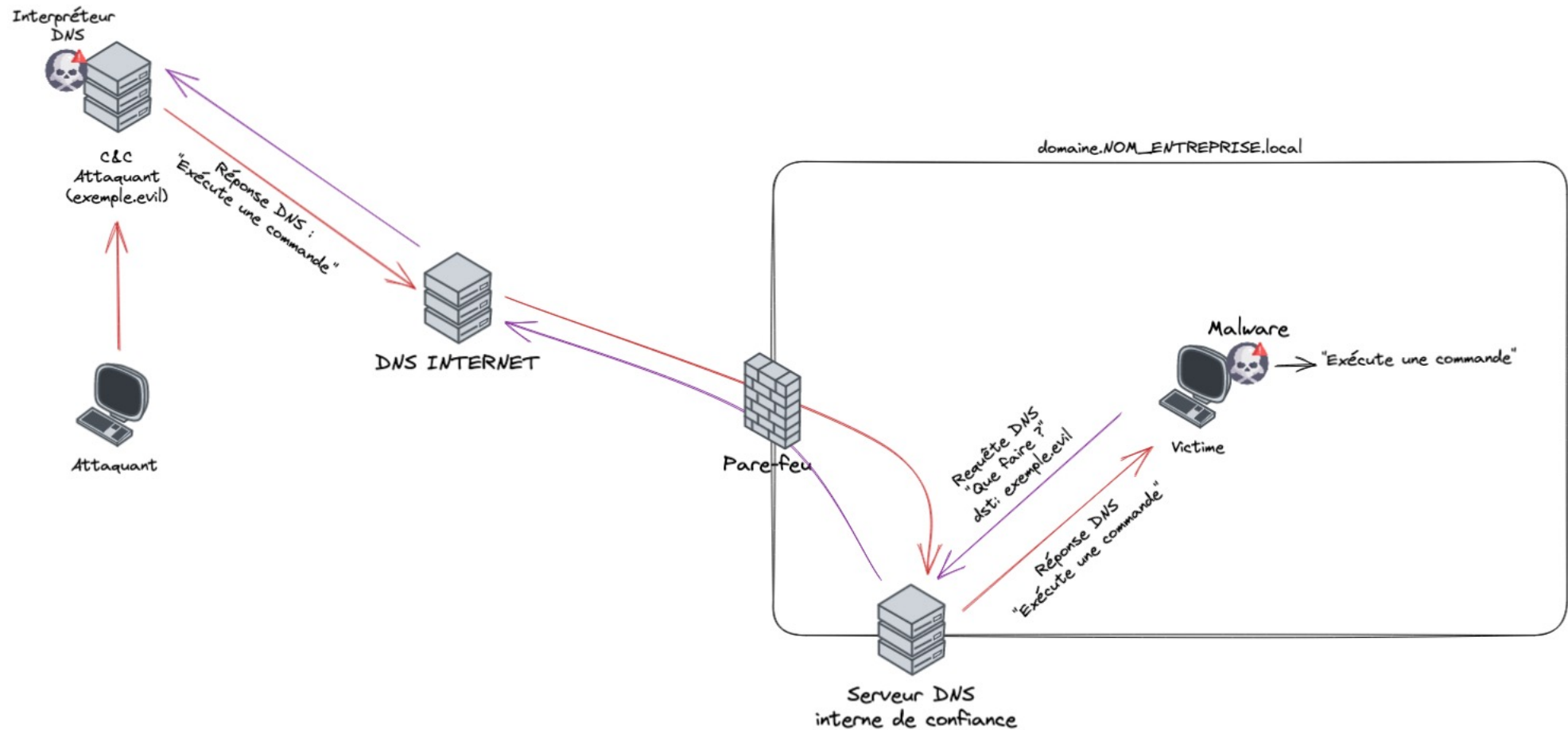
Below the table is a 'DETECTION' tab, which is active. It includes a link to [Join the VT Community](#) and a section for 'Security vendors' analysis'. This section contains a table of vendor results:

Vendor	Result
Dr.Web	Malicious
Fortinet	Malware
Heimdal Security	Malicious
Abusix	Clean

At the bottom right, there is a checkbox labeled 'Do you want to automate checks?'.

15

Détournement du protocole DNS



L'amplification DNS

Usurpation DNS

Les tunnels DNS

L'empoisonnement DNS

Détection et investigation

Analyse de paquets : Rechercher des données qui sortent de la normale (analyse statistique)

Analyse de trafic : Comparer les requêtes DNS à un trafic « usuel » (Ex : identifier les requêtes de type TXT record).

Exemple d'une requête DNS suspecte : **MRZGS3TLEBWW64TFEBXXMYLMORUW4ZI.t.example.com**.

Historique des domaines contactés.

Géolocalisation des IPs : Attention néanmoins, **fiabilité variable dans le temps**.

Le nombre de nom d'hôtes par domaine (une requête unique par nom de domaine).

La visualisation ! Le trafic DNS malveillant saute à l'œil directement lors de construction de graphiques.

1	0.000000	192.168.56.101	192.168.56.1	DNS	92	Standard query	0x36e5 CNAME 65be01241015bae363.jz-n-bs.local
2	0.000961	192.168.56.1	192.168.56.101	DNS	138	Standard query response	0x36e5 CNAME 65be01241015bae363.jz-n-bs.local CNAME b71a012410e36315ba.jz-n-bs.local
3	1.093417	192.168.56.101	192.168.56.1	DNS	92	Standard query	0x2f1b CNAME 019d01241015bae363.jz-n-bs.local
4	1.094420	192.168.56.1	192.168.56.101	DNS	172	Standard query response	0x2f1b CNAME 019d01241015bae363.jz-n-bs.local CNAME e6dd012410e36315ba000000d00010003666c61672e706e6700.jz-n-bs.local
5	1.203268	192.168.56.101	192.168.56.1	DNS	293	Standard query	0x5d8a TXT 6c0601241015bae37400001b158001000389504e470d0a1a0a000000d49.484452000028000001e008060000035d1dce40000006624b474400ff.00ff00ffa0bda793000000
6	1.204320	192.168.56.1	192.168.56.101	DNS	324	Standard query response	0x5d8a TXT 6c0601241015bae37400001b158001000389504e470d0a1a0a000000d49.484452000028000001e008060000035d1dce40000006624b474400ff.00ff00ffa0bda793000000
7	1.204907	192.168.56.101	192.168.56.1	DNS	293	Standard query	0x4a87 MX 584c012410161de3740000001974455874436f6d6d656e74004372656174.656420776974682047494d5057810e1700001a794944415478daeddd7b70.54e5e1f8e137404092004a0
8	1.205791	192.168.56.1	192.168.56.101	DNS	341	Standard query response	0x4a87 MX 584c012410161de3740000001974455874436f6d6d656e74004372656174.656420776974682047494d5057810e1700001a794944415478daeddd7b70.54e5e1f8e13740
9	1.206501	192.168.56.101	192.168.56.1	DNS	293	Standard query	0x7827 MX 45f40124101680e3746cada3e8a8ad8a565bb9e3a55ea8dce28820a946a.0c8a5a44915b1b05040231bcbf3f7e5fcccc926cae9b9b3ccf4c6636d9b3.2767d4dd3dfbd9d73cee6c
10	1.207431	192.168.56.1	192.168.56.101	DNS	341	Standard query response	0x7827 MX 45f40124101680e3746cada3e8a8ad8a565bb9e3a55ea8dce28820a946a.0c8a5a44915b1b05040231bcbf3f7e5fcccc926cae9b9b3ccf4c6636d9b3.2767d4dd3dfbd9d73cee6c
11	1.208190	192.168.56.101	192.168.56.1	DNS	293	Standard query	0x7050 CNAME 6a4101241016e3c37401001080000008400000042000002100000010800.80000400108000000840000004200000210000001080000000400400002.00200001001080000008
12	1.209072	192.168.56.1	192.168.56.101	DNS	339	Standard query response	0x7050 CNAME 6a4101241016e3c37401001080000008400000042000002100000010800.80000400108000000840000004200000210000001080000000400400002.00200001001080000008
13	1.209788	192.168.56.101	192.168.56.1	DNS	293	Standard query	0x05d1 TXT 1f810124101746e374000400400002002000010010800000084000000420.00000210000001080020000100108000000840000004200000210000001.080000004004000020020
14	1.210644	192.168.56.1	192.168.56.101	DNS	324	Standard query response	0x05d1 TXT 1f810124101746e374000400400002002000010010800000084000000420.00000210000001080020000100108000000840000004200000210000001.080000004004000
15	1.211371	192.168.56.101	192.168.56.1	DNS	293	Standard query	0x16fa CNAME 2d0d01241017a9c374000210000001080000008400400002002000010010.80000008400000042000002100040000200200001001080000008400000.04200000021000000108

```
Frame 5: 293 bytes on wire (2344 bits), 293 bytes captured (2344 bits) on interface 0
Ethernet II, Src: PcsCompu_55:59:8f (08:00:27:55:59:8f), Dst: 0a:00:27:00:00:00 (0a:00:27:00:00:00)
Internet Protocol Version 4, Src: 192.168.56.101, Dst: 192.168.56.1
User Datagram Protocol, Src Port: 52273, Dst Port: 53
Domain Name System (query)
  Transaction ID: 0x5d8a
  > Flags: 0x0100 Standard query
  Questions: 1
  Answer RRs: 0
  Authority RRs: 0
  Additional RRs: 0
  > Queries
    > [truncated] 6c0601241015bae37400001b158001000389504e470d0a1a0a000000d49.484452000028000001e008060000035d1dce40000006624b474400ff.00ff00ffa0bda79300000097048597300000b1301009a9c1800.00000774494d4507e1061b083806e97b0fcf.jz-n-b
    [Response In: 6]
```

17

Les protocoles ciblés sur WINDOWS : NTLM

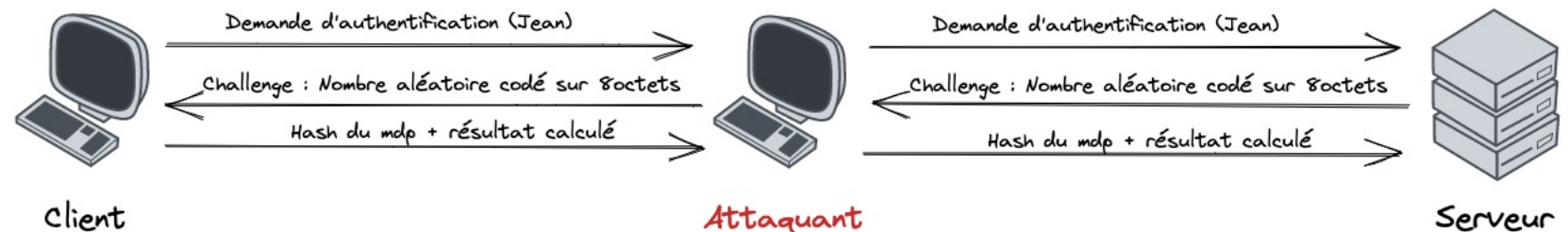
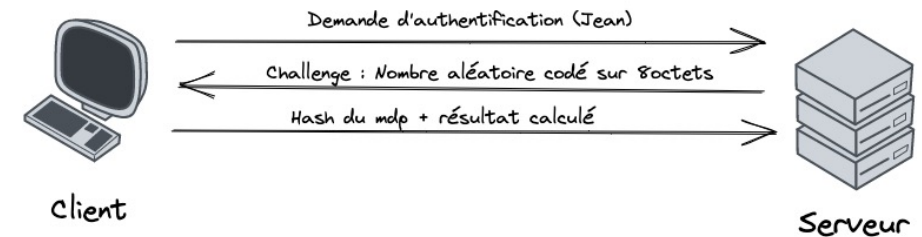
LM et NTLM : Anciens protocoles, mais sont toujours supportés.

NTLMv1 et LM : Vulnérables, brute-force, pass the hash..,

NTLMv2 : développé suite aux multiples attaques

Problèmes liées à NTML :

- Le secret utilisateur est exposé (parfois directement) durant certaines phases de l'authentification.
- On authentifie le client mais pas ...?



18

Les protocoles ciblés sur WINDOWS : NTB-NS et LLMNR

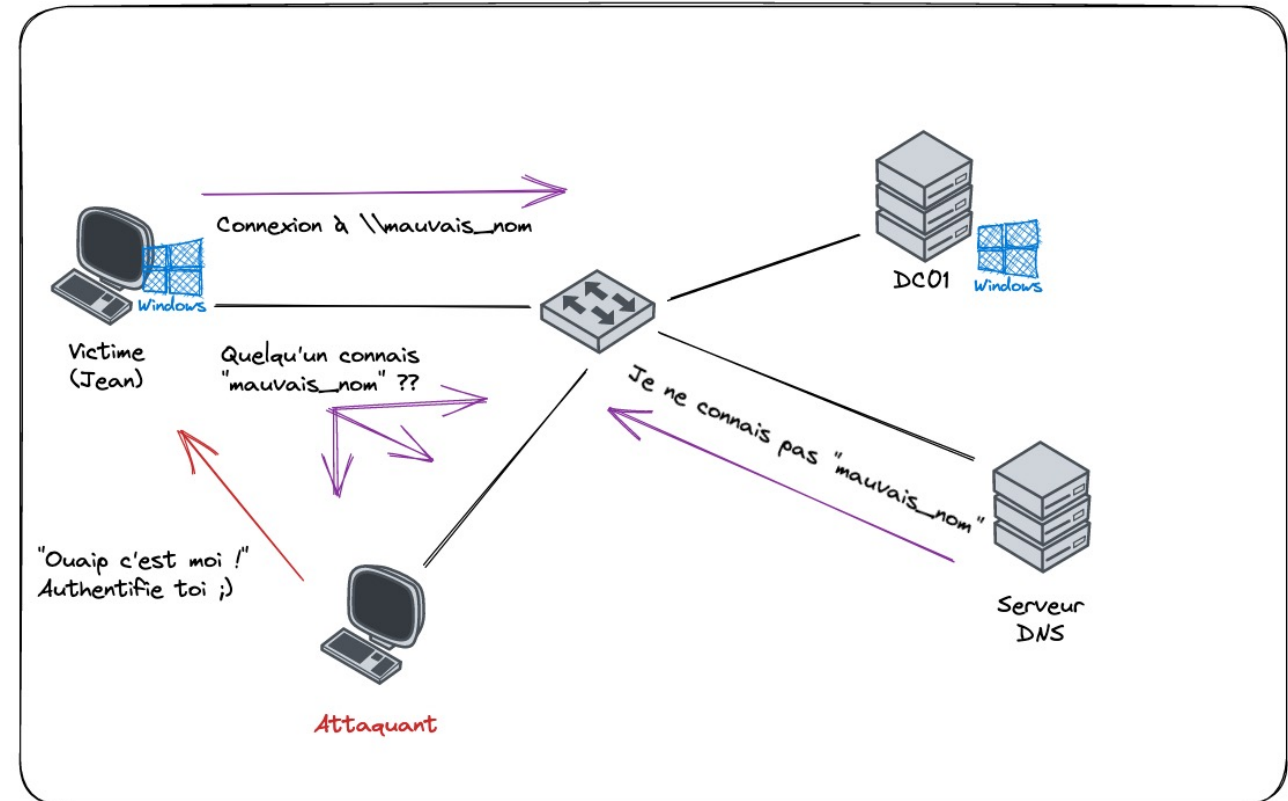
• NBT-NS (NetBios Name Resolution)

- broadcast (UDP/137)

• LLMNR (Link Local Multicast Name Resolution)

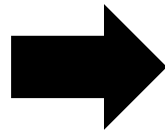
- multicast (UDP/5355)

Deux protocoles obsolètes de Microsoft : **activés par défaut!**



Les attaques sur NTB-NS et LLMNR : Responder

```
--version          show program's version number and exit
-h, --help        show this help message and exit
-A, --analyze      Analyze mode. This option allows you to see NBT-NS,
                   BROWSER, LLMNR requests without responding.
-I eth0, --interface=eth0
                   Network interface to use, you can use 'ALL' as a
                   wildcard for all interfaces
-i 10.0.0.21, --ip=10.0.0.21
                   Local IP to use (only for OSX)
-m 2002:c0a8:f7:1:3ba8:aceb:b1a9:81ed, --externalip6=2002:c0a8:f7:1:3ba8:aceb:b1a9:81ed
                   Poison all requests with another IPv6 address than
                   Responder's one.
-e 10.0.0.22, --externalip=10.0.0.22
                   Poison all requests with another IP address than
                   Responder's one.
-b, --basic        Return a Basic HTTP authentication. Default: NTLM
-d, --DHCP         Enable answers for DHCP broadcast requests. This
                   option will inject a WPAD server in the DHCP response.
                   Default: False
```



[+] Exiting...

Les protocoles ciblés sur LINUX : FTP

Un protocole dont les échanges sont « en clair » sur le réseau. Créé pour transférer des fichiers de manière très facile. Comme tout vieux protocole : Pas pensé avec une dimension sécurité. Son usage peut être dérivé.

- MITM
- Exfiltration de données

The image shows a Wireshark packet capture of an FTP session. The main pane displays a list of packets with columns for No., Time, Source, Destination, Protocol, and Info. A red box highlights the FTP protocol details for several packets, showing a sequence of failed login attempts. The bottom pane shows the expanded details of a specific packet (No. 4), highlighting the '530 Login incorrect' response.

No.	Time	Source	Destination	Protocol	Info
4	0.012755	10.121.70.151	10.234.125.254	FTP	Response: 530 Login incorrect.
10	0.031952	10.121.70.151	10.234.125.254	FTP	Response: 331 Password required for admin.
11	0.032425	10.234.125.254	10.121.70.151	FTP	Request: PASS merlin
13	0.040913	10.121.70.151	10.234.125.254	FTP	Response: 530 Login incorrect.
16	0.050057	10.121.70.151	10.234.125.254	FTP	Response: 331 Password required for admin.
17	0.051363	10.234.125.254	10.121.70.151	FTP	Request: PASS mercury
19	0.052900	10.121.70.151	10.234.125.254	FTP	Response: 331 Password required for admin.
20	0.059083	10.121.70.151	10.234.125.254	FTP	Response: 331 Password required for admin.
21	0.059593	10.234.125.254	10.121.70.151	FTP	Request: PASS mets
29	0.108560	10.121.70.151	10.234.125.254	FTP	Response: 530 Login incorrect.
32	0.120024	10.121.70.151	10.234.125.254	FTP	Response: 530 Login incorrect.
39	0.145896	10.121.70.151	10.234.125.254	FTP	Response: 530 Login incorrect.
47	0.195865	10.234.125.254	10.121.70.151	FTP	Request: PASS mgr
52	0.207636	10.121.70.151	10.234.125.254	FTP	Response: 220 FTP Service

Expanded details for packet 4 (File Transfer Protocol (FTP)):

```

530 Login incorrect.\r\n
  Response code: Not logged in (530)
  Response arg: Login incorrect.
  [Current working directory: ]
  
```


- Introduction
- Les différents types de journaux réseau
- Techniques, tactiques et procédures des attaquants
- **Méthodologie de surveillance**
- Les outils d'investigation et de détection
- Méthodologie d'investigation

Méthodologie de surveillance

Capter l'ensemble du trafic réseau :

Il est garanti qu'il n'existe aucune perte d'évènements. En revanche, cette méthodologie gaspille du temps, et peut créer rapidement un vrai problème de volumétrie dans le temps.

Capture & Parse (CAP) : Capturer uniquement les paquets suspect et méritant une analyse en profondeur :

Cette méthode permet le contrôle de la volumétrie et du stockage. Cependant des évènements peuvent être ratés et nécessitera plus de ressources (mise en place d'un tap, utilisation de regexp).

Attention : besoin fort niveau ressources (CPU).

Les équipements de sécurité indispensables

Web Application Firewall (WAF)

Content Delivery Network (CDN)

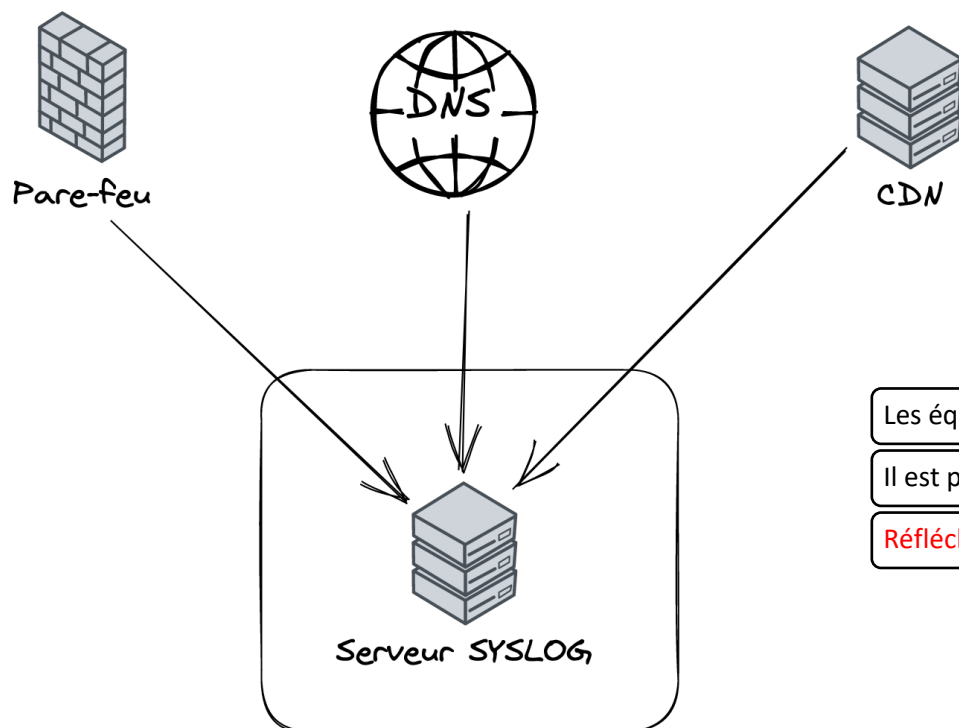
Proxy

Pare-feux

NIPS/NIDS

SIEM

Intégrer les équipements réseau à la collecte centralisée



Les équipements réseaux possèdent en général un connecteur **rsyslog**

Il est parfois nécessaire d'effectuer un travail de normalisation des journaux une fois ces derniers centralisés.

Réfléchir à la l'interconnexion éventuelle avec un SOC (interne ou externe).

- Introduction
- Les différents types de journaux réseau
- Techniques, tactiques et procédures des attaquants
- Méthodologie de surveillance
- Les outils d'investigation et de détection
- Méthodologie d'investigation

Les outils d'investigation et de détection

Wireshark

➤ <https://www.wireshark.org/>

Zeek/corelight

➤ <https://corelight.com/products/compare-to-zeek>

DNShunter

➤ <https://github.com/slacker007/DNShunter>

Elasticsearch/Kibana

➤ <https://www.elastic.co/fr/blog/analyzing-network-packets-with-wireshark-elasticsearch-and-kibana>

Snort

➤ <https://www.snort.org/>

NetworkMiner

➤ <https://www.netresec.com/?page=NetworkMiner>

Python

➤ Apprendre à faire des parser rapidement

BRIM

➤ <https://www.brimdata.io/>

- Introduction
- Les différents types de journaux réseaux
- Techniques, tactiques et procédures des attaquants
- Méthodologie de surveillance
- Les outils d'investigation et de détection
- Méthodologie d'investigation

Méthodologie d'investigation dans le cadre d'un incident

1. **Planifier** l'enquête.
2. Collecter et **documenter** les artefacts réseau.
3. Filtrez les données.
4. Analyser les artefacts réseau.
5. Identifier la source de l'attaque et extraire les **indicateurs**, **techniques**, **tactiques** et **procédures**.
6. **Documenter** vos activités et proposer vos conclusions.
7. **Présenter** les résultats.
8. Présenter les mesures de **remédiation**.



29 Conclusions et limites

Collecte et stockage des journaux

Difficulté d'interprétation

Manque d'informations contextuelles

Vos questions